

Botium Toys - Audit & Rapport de Sécurité

Évaluation de la portée, des objectifs, des risques et des contrôles de conformité

Auteur : JOHAN ELLOH

Cadre : Google Cybersecurity Professional Certificate

Organisme fictif : Botium Toys Inc.

Score de Risque Globale : 8 / 10 (Élevé)

Note de contexte : Ce document constitue une étude de cas basée sur un scénario d'entreprise fictive réalisé dans le cadre du certificat professionnel Google Cybersecurity.

1. Portée et Objectifs de l'Audit

Portée : L'audit couvre l'intégralité du programme de sécurité informatique de *Botium Toys*. Cela englobe tous les actifs matériels et logiciels, les processus internes, ainsi que les procédures de mise en œuvre des contrôles de sécurité et des meilleures pratiques de conformité réglementaire.

Objectifs : Évaluer les actifs existants, compléter les checklists de contrôles et de conformité, et déterminer les actions prioritaires pour renforcer la posture de sécurité globale de l'entreprise.

2. Inventaire des Actifs Sécurisés & État des Lieux

Les actifs gérés par le département IT comprennent notamment :

- **Équipements de bureau et terminaux :** Desktops, laptops, smartphones, postes distants, casques, stations d'accueil, caméras de surveillance.
- **Produits en magasin & Entrepôt :** Stocks de jouets vendus sur site et en ligne, stockés dans l'entrepôt contigu.
- **Services & Systèmes d'information :** Comptabilité, télécommunications, bases de données, sécurité, e-commerce, gestion des stocks et accès Internet.
- **Infrastructures réseaux :** Réseau interne, systèmes de conservation/stockage de données, et maintenance manuelle des systèmes hérités (Legacy end-of-life).

3. Grille des Contrôles de Sécurité (Checklist)

Contrôle de Sécurité	En Place ?	Catégorie	Type
Moindre Privilège (Least Privilege)	Non	Administratif	Préventif
Plan de Reprise d'Activité (Disaster Recovery Plan)	Non	Administratif	Correctif
Politiques de Mots de Passe (Password Policies)	Non*	Administratif	Préventif
Séparation des Tâches (Separation of Duties)	Non	Administratif	Préventif
Pare-feu (Firewall)	Oui	Technique	Préventif
Système de Détection d'Intrusions (IDS)	Non	Technique	Détectif
Sauvegardes (Backups)	Non	Technique	Correctif
Logiciel Antivirus (AV)	Oui	Technique	Correctif
Surveillance & Maintenance des Systèmes Hérités (Legacy)	Oui	Technique	Préventif
Chiffrement des Données (Encryption)	Non	Technique	Dissuasif
Gestionnaire Centralisé de Mots de Passe	Non	Technique	Préventif

Contrôle de Sécurité	En Place ?	Catégorie	Type
Serrures physiques (Bureaux, Entrepôt, Magasin)	Oui	Physique / Opérationnel	Préventif / Dissuasif
Vidéosurveillance CCTV	Oui	Physique / Opérationnel	Préventif / Détectif
Systèmes de Détection & Extinction Incendie	Oui	Physique / Opérationnel	Détectif / Préventif

* Remarque : Une politique existe mais est jugée nominale et non conforme aux exigences minimales modernes.

4. Checklist de Conformité Réglementaire

A. Payment Card Industry Data Security Standard (PCI DSS)

Pratique de Conformité	Respecté ?
Accès restreint aux données de cartes bancaires aux seuls utilisateurs autorisés	Non
Stockage, traitement et transmission sécurisés des données bancaires en interne	Non
Mise en œuvre de procédures de chiffrement pour sécuriser les flux et données carte	Non
Adoption de politiques sécurisées de gestion des mots de passe	Non

B. General Data Protection Regulation (GDPR / RGPD)

Pratique de Conformité	Respecté ?
Protection et confidentialité des données des clients de l'Union Européenne	Non
Plan de notification des clients UE sous 72h en cas de violation de données	Oui
Classification et inventaire rigoureux des données	Non
Application de politiques et procédures documentées de confidentialité des données	Oui

C. System and Organization Controls (SOC Type 1 & Type 2)

Pratique de Conformité	Respecté ?
Établissement de politiques strictes d'accès utilisateur	Non
Confidentialité et protection des données sensibles (PII / SPII)	Non
Intégrité des données (consistance, exactitude et validation intégrées)	Oui
Disponibilité des données assurée aux utilisateurs autorisés	Oui

5. Évaluation des Risques & Analyse NIST CSF

NIST CSF - Fonction IDENTIFY : Botium Toys doit consacrer des ressources prioritaires à l'identification et à la classification de ses actifs afin de déterminer l'impact de la perte potentielle d'un système sur la continuité des activités.

Score de Risque Globale : 8 / 10 (Élevé). Ce score provient de l'absence de contrôles d'accès, de l'absence de chiffrement des données sensibles et du manque de sauvegardes/plan de reprise d'activité.

6. Recommandations Prioritaires & Plan d'Action

1. Urgence Absolue – Chiffrement & Conformité PCI DSS

- **Action** : Chiffrer les données de cartes bancaires et PII/SPII au repos et en transit.
- **Objectif** : Prévenir les fuites de données et assurer la conformité PCI DSS.

2. Gestion des Accès et des Identités (IAM)

- **Action** : Appliquer le *Moindre Privilège*, la *Séparation des Tâches* et déployer un gestionnaire de mots de passe centralisé.
- **Objectif** : Limiter les risques de menaces internes.

3. Sécurisation Réseau & Systèmes Hérités (Legacy)

- **Action** : Conserver le pare-feu fonctionnel actuel, ajouter un **Système de Détection d'Intrusions (IDS)** et formaliser la maintenance des systèmes hérité.
- **Objectif** : Détecter les anomalies et sécuriser les composants obsolètes.

4. Continuité d'Activité et Résilience

- **Action** : Rédiger un plan de reprise d'activité (Disaster Recovery Plan) et automatiser les sauvegardes (Backups).
- **Objectif** : Assurer la résilience de l'entreprise.

5. Gouvernance et Conformité GDPR / SOC

- **Action** : Classifier les données personnelles et formaliser les contrôles d'accès.
- **Objectif** : Répondre aux exigences RGPD et SOC 1/2.